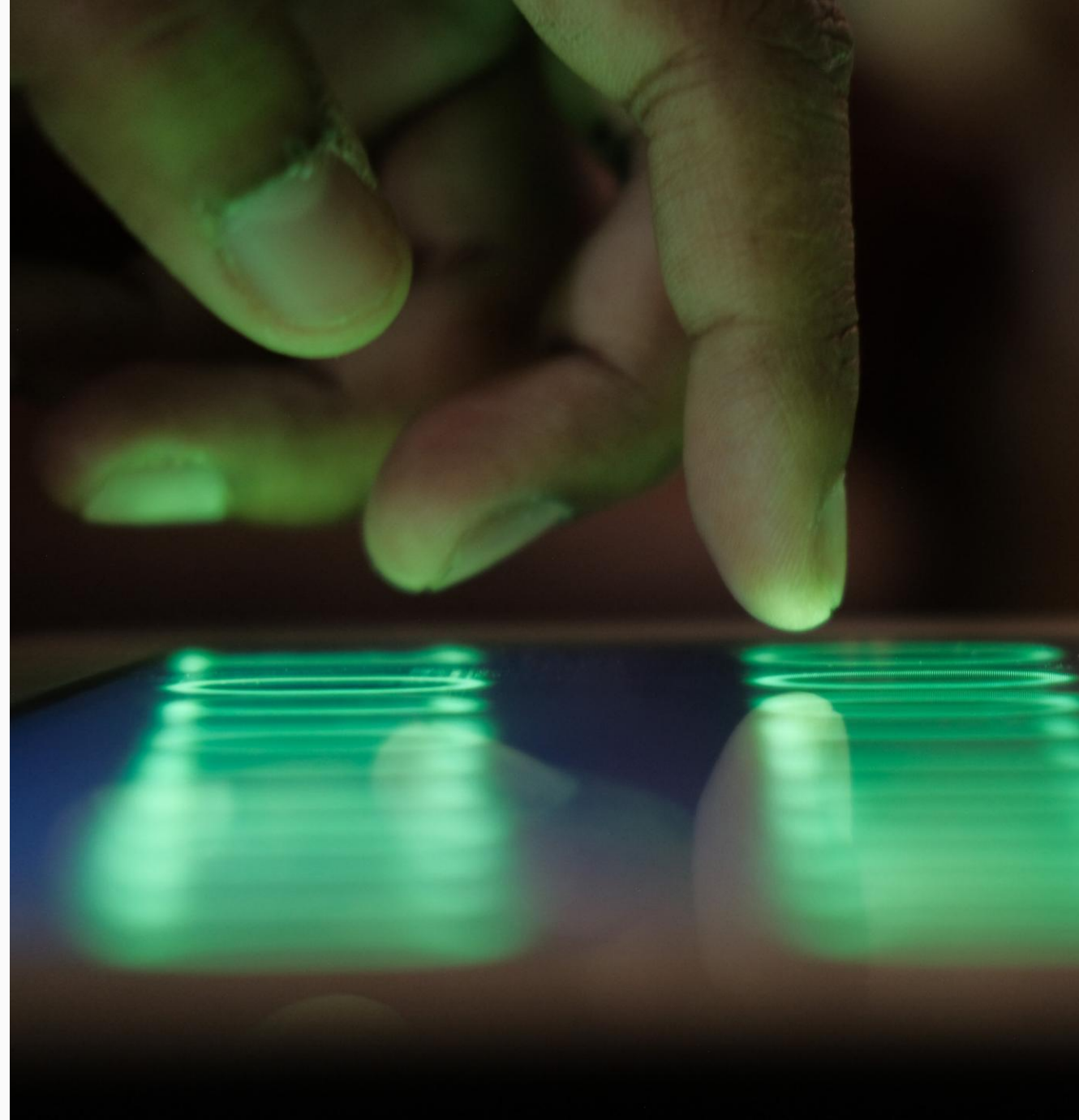


今から始める セキュリティ入門 【Web編】

～PortSwiggerのWeb Security Academyで
遊んでみよう～



セキュリティ業界未経験からセキュリティに興味を持った人が、次の目標を見つけて一歩踏み出せるようになること。

- セキュリティ興味があるけど
何から始めたらいいかわからない...
- CTFに参加してみたものの
解き方がよくわからない...
- CTFに挑戦しwriteupを読んでも
理解できない...
- 勉強会に参加してみたものの
手を動かしておらず、
技術が身に着いているのか不安...

まずはPortSwiggerが提供する

『Web Security Academy』で遊んでみよう！

- 脆弱性を理解するための解説コンテンツあり
- 実際に動かして体験できるラボあり
- ラボの解き方の解説動画もある
- 無料で体験可能

目標と得られること（効果）

本資料ではWEBセキュリティに焦点を当て、環境構築を完了し、今回紹介する学習コンテンツ（Web Security Academy）を始められる状態にする。

目標：

- 環境構築およびサイトへの登録を完了する
- すぐに学習を始められる状態にする

得られる効果：

- 無料でWebセキュリティを学べる環境を整えることができる
- 手を動かして問題を解くことで成功体験が得られる

結論：おすすめする環境構成

学生や社会人が個人的に学ぶ環境ということを踏まえ『利便性』『安全性』『コスト』などを総合的に考えると、仮想環境を立てる方法が最もおすすめ。

	実機環境	仮想環境（VirtualBoxなど）	クラウド環境
利便性	● セットアップが簡単 ● ハードウェアのリソースをフル活用できる ● 環境をリセットしづらい ● 再インストール時の手間やデータ損失リスク	環境の復元が容易 ● スナップショット機能で環境を容易に復元できる ● VMのセットアップに多少の手間がかかる	● 高性能なリソースを必要に応じて利用可能 ● スケーラビリティが高く、環境を即座に作り直せる
安全性	● 実機がマルウェア感染するリスク ● ネットワーク全体への影響の可能性	安全性が高い ● ホストOSを保護しつつ、隔離された環境で検証可能	● ローカル環境を汚さず、リスクが少ない ● クラウドサービスのセキュリティポリシーや規約によって制約がある可能性 ● 適切なアクセス制御が必要
コスト	● 実機環境で動かすため、利用コストはかからない ● ツールを動かす最低限のリソースやスペックがあれば問題ない	コストを抑えられる ● ローカルで動作するためクラウド利用コストがかからない ● ある程度物理マシンのリソースが必要（CPU、メモリ、HDD容量）	● クラウドの利用コストが発生 ● クラウド上にあるマシンの管理コスト（手間）もある

結論：おすすめする教材(コンテンツ)

WEBセキュリティに絞るのであれば、情報がまとめられ実際に手を動かして体験も出来るPortSwiggerの『Web Security Academy』がおすすめ。

	TryHackMe	Web Security Academy	Hack The Box
対象者	初心者～中級者	初心者～中級者	中級者～上級者
特徴	ブラウザ上で攻撃マシンを提供し、ハンズオン形式で学習可能。一部のプレミアムコンテンツは有料。	Webセキュリティ学習中心のコンテンツ。基本的に無料で学べ、Burp Suiteを活用した解説動画もある。	主にレッドチーム向けの問題が多く、解説は基本的になく、自力での解決が求められる。
手間	低 (環境構築不要)	中 (BurpSuiteを利用できる環境が必要)	高 (VPN接続などの準備が必要)
難易度	★★☆☆☆ (易しめ)	★★★★☆ (やや簡単)	★★★★★ (難しい)
課金要素	一部課金が必要 ※プレミアムコンテンツは有料会員のみ ※無料ユーザーは1日1時間のマシン利用制限有り	ラボの利用は基本無料 ※一部Burp Suiteの有料機能が必要	一部課金が必要 ※課金によりブラウザ上で攻撃マシンを利用可能。
コンテンツ数※	約800以上のルーム※ (2024年時点)	150以上のラボ※ (2024年時点)	約300以上のマシン※ (2024年時点)

※: コンテンツ数は2024年時点の情報であり、現在の数とは異なる可能性があります。最新の情報は各プラットフォームの公式サイトでご確認ください。

前半に事前に知っておくべき知識を座学として簡単に説明。後半に実践形式で画面（デモ）を見せながら説明をする。

STEP1. 座学

- 概要を理解する
- 本資料では概要をスライド形式でざっくり解説

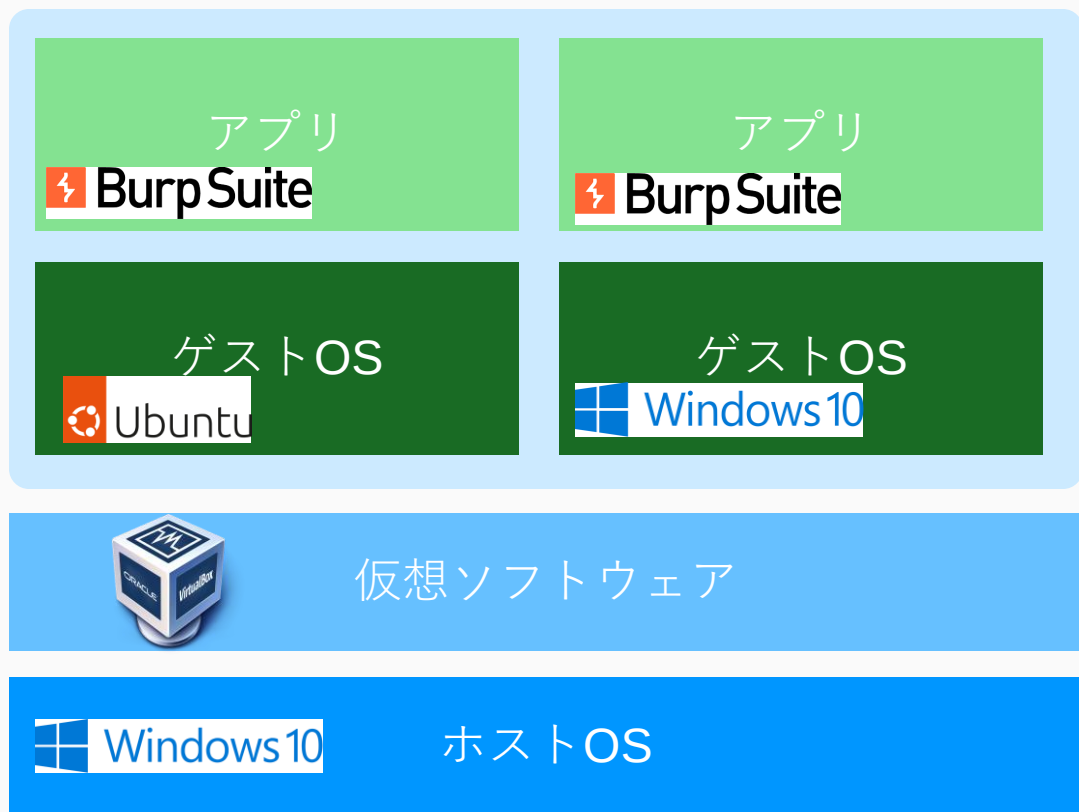
STEP2. 実践

- 学んだことを実際に試して体験する
- 実際に操作しているデモを流しながら解説

座学：仮想環境とは？

仮想環境は**1台のPC**の中に別のマシン（仮想マシン）を作り出せる技術。実機を使わず、自由にテスト・検証ができるため、セキュリティの学習に持ってこい。

物理的なPC(実機)の中に複数マシンを構築可能



仮想環境を使うメリット

✓ **安全性が高い：**

本体（ホストOS）に影響を与えずに、テストや検証ができる。

✓ **環境構築が楽：**

必要なツールを簡単にセットアップできる。

✓ **スナップショット機能：**

環境を壊しても、元の状態に簡単に戻せる。

✓ **コスト削減：**

実機を増やさずに複数のOSや環境を用意できる。

座学：仮想環境はVirtualBoxがオススメ

理由は無料で使えることと必要な機能が大体揃っているため。後は単純に発表者（私）が使い慣れているから。つまり、VirtualBoxでなくても何でも良い。



VirtualBoxとは？

- **VirtualBox** は、オラクル社が提供する**無料**の仮想マシンソフトウェア。
- Windows、Mac、Linuxで動作し、さまざまなOSをインストール可能。
※M1、M2などのAppleシリコンにも対応
- 初学者でも簡単に仮想環境を構築できる。

VirtualBoxをおすすめする理由

- ✓ **無料で利用可能：**
オープンソースのため、コストをかけずに使える。
- ✓ **マルチプラットフォーム対応：**
Windows、Mac、Linuxで動作。
- ✓ **簡単な操作性：**
GUIで直感的に仮想マシンを作成・管理できる。
- ✓ **スナップショット機能：**
失敗しても元の状態に戻せるので、安心して実験可能。
- ✓ **軽量で動作が安定：**
初心者でも快適に仮想環境を構築できる。
- ✓ **広く使われている：**
情報が多く、トラブルシューティングもしやすい。

Debian系列のLinux OS。世界的にもシェアを持ちネット上に情報量が多いためトラブルシューティングに便利。使いこなしておいて損はないOS。

Ubuntuの概要と選ぶメリット

- Ubuntu は、Linuxの代表的なディストリビューション(OS)。
- 無料で使えるオープンソースのOSで、企業やサーバーでも広く利用されており初心者でも扱いやすい。
- Kali Linuxと同じDebian系で、将来的にKaliの学習にもつながる。
- 世界中で利用されているため、困ったときに解決策を見つけやすい。

他のLinuxとの比較

ディストリビューション	シェア (%) ※2022年4月
Ubuntu	34.4%
Debian	15.8%
CentOS	9.4%
Red Hat	0.8%
Gentoo	0.5%
Fedora	0.2%
SuSE	0.1%

出展： [Beginet Q-Success](#)、2022年4月のWebサイト向けLinuxディストリビューションのシェアランキングを発表

座学：PortSwiggerとは？



セキュリティ業界で知らない人はいない企業。世界のWebを安全にするという使命を持ち情報発信、学習コンテンツの提供、診断ツール（Burp Suite）の展開をしている。

PortSwiggerの理念



展開している製品・サービス

 **Burp Suite**

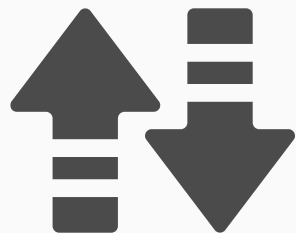
Web Security Academy 

 **PortSwigger Research**

WEBの脆弱性調査などでよく使われるツール。リバースプロキシ機能や脆弱性スキャン(有料)など様々な機能を持つのが特徴。今回紹介するコンテンツを遊ぶ分には無料版で問題ない。

代表的な機能

Burp Proxy



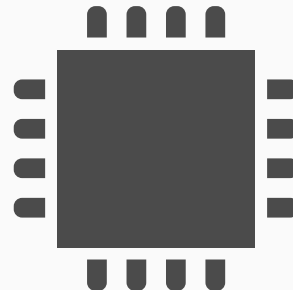
Webブラウザとサーバー間の通信を傍受し、データの確認・編集が可能

Burp Scanner



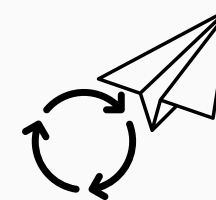
SQLインジェクションやXSSなどの脆弱性を自動検出
(有料版のみ)

Burp Intruder



パラメータを変更しながら攻撃を試行する自動化ツール
(無料版は一部制限あり)

Burp Repeater



特定リクエストを繰り返し送信し、レスポンスを比較

(参考) Burp Suiteの有償版と無償版の違い



Burp Suite Community Edition

Essential manual toolkit - perfect for learning more about AppSec.

What's included?

Community

- ✓ HTTP(s) / WebSockets proxy and history.
- ✓ Essential tools - Repeater, Decoder, Sequencer, and Comparer.
- ✓ Burp Intruder (demo).

Burp Suite Professional

Faster, more reliable security testing for AppSec professionals.

Professional

- ✓ **Everything in Community Edition, plus ...**
- ✓ Project files (save your work).
- ✓ Orchestrate custom attacks (Burp Intruder - full version).
- ✓ Web vulnerability scanner.
- ✓ Pro-exclusive BApp extensions.
- ✓ Search function.
- ✓ Auto and manual OAST testing (Burp Collaborator).
- ✓ Automatically crawl and discover content to test.
- ✓ And much more ...

BUY NOW - \$475

[Find out more →](#)

座学： Web Security Academyとは？

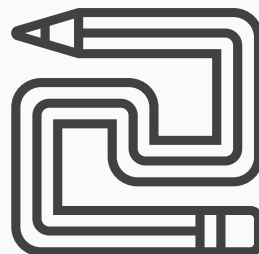
PortSwiggerが提供する無料でWebセキュリティを学ぶことができるトレーニングコンテンツ。世界トップクラスのセキュリティ専門家が制作している。

キャリアアップ



Web Security Academyは、サイバーセキュリティ分野でのキャリアに向けた強力な一歩です。

フレキシブルな学習



無料のインタラクティブなラボと進捗管理で、いつでもどこでも学習できます。

エキスパートから学ぶ



『The Web Application Hacker's Handbook』の著者が率いる世界トップクラスのチームが制作。

座学：『Server-side vulnerabilities』から始めてみよう

今回はAcademyの中でも初学者向けのコンテンツとなる「Server-side vulnerabilities」を少し紹介。テーマごとに解説ページもあり入門的なコンテンツとしてピッタリ。

主な学習内容

- ✓ パストラバーサル
- ✓ アクセス制御
- ✓ リクエストパラメータの不備
- ✓ 認証系に関する不備（総当たり攻撃、など）
- ✓ 二要素認証の不備
- ✓ SSRF
- ✓ ファイルアップロード機能の不備
- ✓ OSコマンドインジェクション
- ✓ SQLインジェクション

学習ページもあり



※コンテンツ内容の詳細は直接ログインして参照頂きたい

実践：作業の流れ

環境構築を行いPortSwiggerにアカウント登録を完了する。登録完了後、Web Security Academyのおすすめコンテンツを紹介し、実演も行う。

環境構築

PortSwigger アカウント登録

PortSwigger Web Security Academy ラボに挑戦

- VirtualBoxのインストール
- OS(Ubuntu)のDL(ダウンロード)
- VirtualBox上にてゲストOS作成
- VirtualBox Guestイメージのインストール
- BurpSuitのDL、インストール、設定

- PortSwiggerにアクセス
- PortSwiggerへのアカウント登録

- ラボの初学者向けコンテンツにアクセス
- 演習の様子の一部を紹介

Windows（ホスト側）にVirtualBoxをインストールし、VMとしてUbuntu（ゲストOS）を構築する。まずは必要なものをダウンロード（DL）する。

VirtualBoxのDLおよびセットアップ

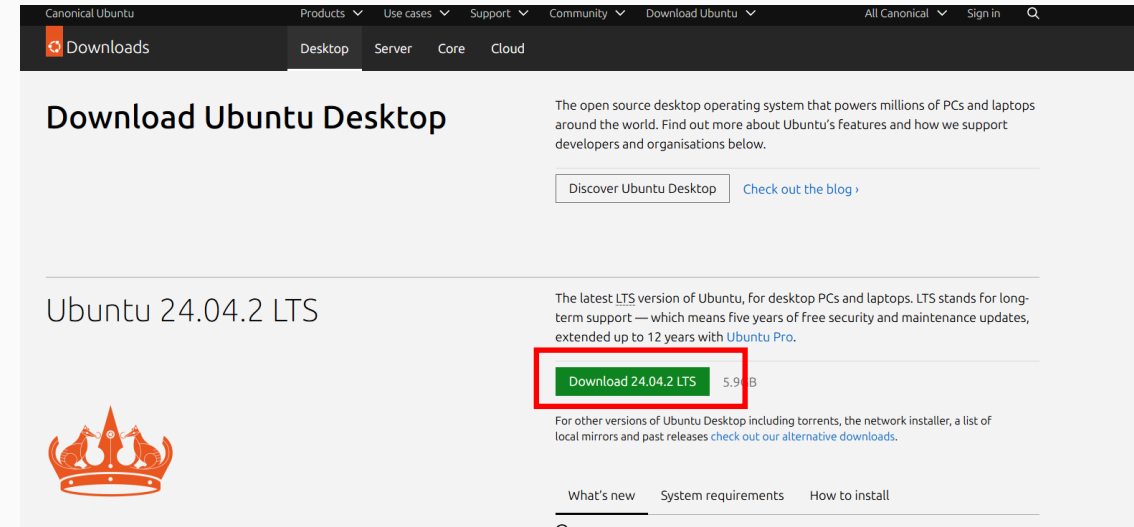
- ダウンロードは以下リンク先の公式サイトから
- ウィザードに従ってセットアップすればOK



[Download VirtualBox](#)

UbuntuのDL

- ダウンロードは以下リンク先の公式サイトから
ISOファイルをダウンロードする



[Download Ubuntu Desktop](#)

実践：環境準備（ホストOS側） VirtualBox環境上にUbuntuを構築（2 / 2）

VM作成は「新規」ボタンから。立ち上がったウィザードに従ってマシン名、メモリ、ストレージ容量を決め、DLしたUbuntuのISOイメージを指定し、VMを起動する。

必要なスペックに合わせVM作成

発表者が設定した内容（参考）



項目	設定内容	コメント
名前	Ubuntu-24.04.01	入れたOSバージョンがわかるように
メモリ	4048 MB	4GBあると安定する ※個人の感想
ストレージ	50 GB(可変サイズ)	お使いの空き容量と相談

起動後はUbuntuのセットアップウィザードが立ち上がるので、ウィザード内容に従ってセットアップしていけばOK。基本的にはそのまま「OK」ボタンで次に進めばよい。

※Ubuntuのインストールについては割愛

実践：環境準備（ゲストOS側）にVirtualBox固有の設定を行う

学習を効率よく進めるため、VirtualBox Guestイメージをインストールする。

※詳細はデモ参照

実践：環境準備（ゲストOS側）にBurpをインストール・設定

学習には**Burp Suite**というソフトを使う。インストールだけでなく、自己証明書の設定も行う必要がある。

※詳細はデモ参照

実践：（おまけ）環境準備（ゲストOS側）でChromeをインストール・設定

Chromeの方が使いやすいのと、デフォルトでページ全体をGoogle翻訳してくれる機能があるので別途インストール・設定している。任意程度にとどめてもらえれば。

※詳細はデモ参照

実践： Webセキュリティ学習サイト『PortSwigger』へのアカウント登録

Webセキュリティの主要なものを効率よく無料で学ぶことが可能な
Web Security Academyを遊ぶために、PortSwiggerにアカウント登録する。

※詳細はデモ参照

実践：『Server-side vulnerabilities』を始めてみよう

Web Security AcademyのトップからView Allをクリックし、
「Server-side vulnerabilities」にアクセス。Get Startでコンテンツを始めよう。

※詳細はデモ参照

実践：（おまけ）PortWsigner Web Security Academyをより楽しめるためのノウハウ

「Server-side vulnerabilities」を楽しむために
覚えておくの良いBurpSuiteの機能の一部を紹介する。

※詳細はデモ参照